

Firewall Rules — Victim Interface (VLAN 30, 10.10.30.0/24)

The Victim zone hosts deliberately vulnerable endpoints. It must have **no internet** (to block C2 callbacks / data exfiltration / worm propagation) and must not be able to initiate connections into any other zone. It only responds to traffic initiated by the Attacker (stateful return traffic) and is reachable by the Management plane for triage.

Aliases: RFC1918 , LabNets .

#	Action	Proto	Source	Dest	Port	Description
1	Pass	TCP/UDP	VICTIM net	VICTIM address	53	Local DNS only (internal name res.)
2	Pass	UDP	VICTIM net	This firewall	123	NTP (clock sanity for logs)
3	Block (log)	any	VICTIM net	RFC1918	any	No lateral movement to other zones
4	Block (log)	any	VICTIM net	any	any	No internet — deny all egress

Security note: there is no “allow” rule for outbound internet on purpose. Return traffic to the Attacker works because `pf` is **stateful** — the state created by the Attacker→Victim connection (attacker rule 5) permits the reply packets automatically. We do not need an explicit Victim→Attacker allow, which keeps the victim unable to initiate anything outward.

DNS (rule 1) is restricted to the firewall’s own resolver so that detonated malware can be observed doing DNS lookups (great telemetry) without those lookups ever leaving the lab. Optionally point this at an internal sinkhole.

All blocks are logged — denied egress attempts from a victim are high-signal IOCs for the SIEM in later phases.